

Section 06



Industrial Security (Bachelor)

Section 06 – Vulnerabilities and Assessment

Vulnerabilities and Assessment

Lecture Notes

Department of Computer Science

- 1 Vulnerability Intelligence
- 2 Asset Inventory and Scanning
- 3 Vulnerability Management Workflow

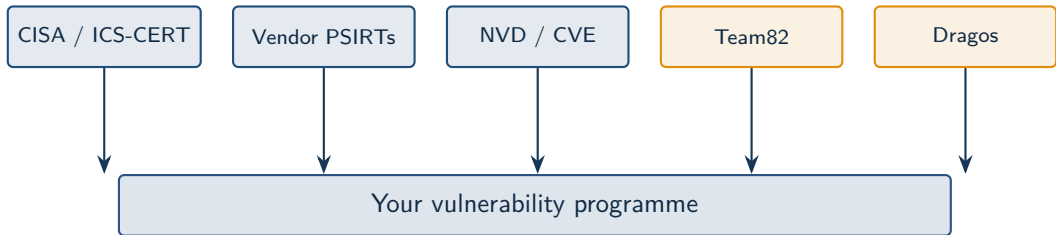
By the end of this section you will be able to

- Find and interpret ICS vulnerability advisories.
- Apply CVSS v3.1 with environmental modifiers in an OT context.
- Plan a safe asset inventory across passive and active methods.
- Run a vulnerability management workflow that fits OT constraints.

1

Vulnerability Intelligence

Section 06 – Vulnerabilities and Assessment



ICSA-25-XXX-NN ACME Controller series X / firmware 2.0–2.4

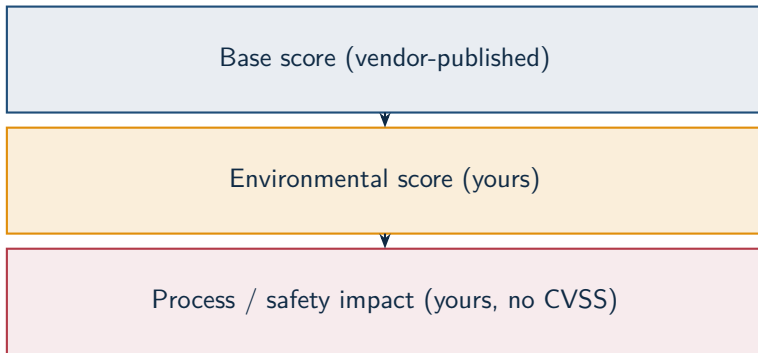
CVSS v3.1: 9.8 / AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CWE-798: Use of hard-coded credentials

Impact: Unauthenticated remote attacker may take control of the device

Mitigation: Upgrade to FW 2.5; segregate behind firewall; disable web UI

Timeline: Reported 2024-11; patched 2025-02; advisory 2025-05

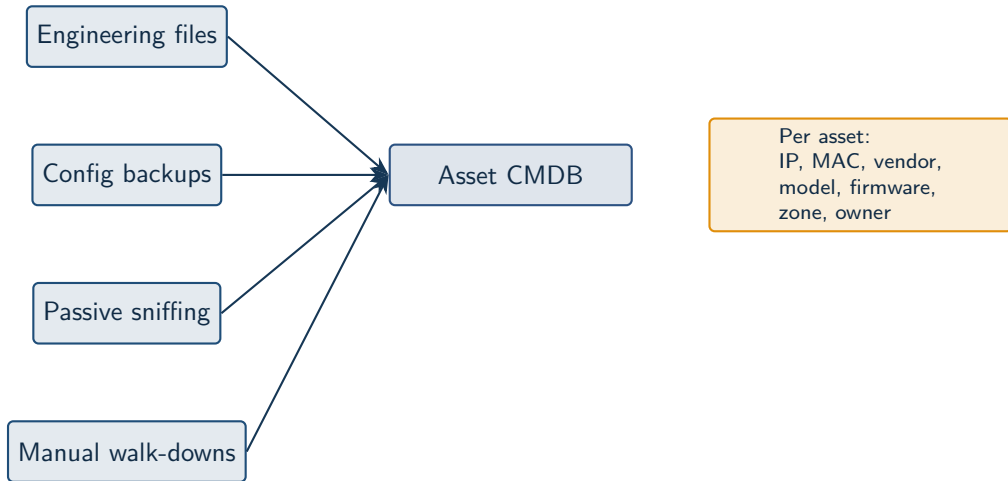


Base alone is misleading. “Low Availability” in IT may equal *plant shutdown* in OT. Always combine with process consequence.

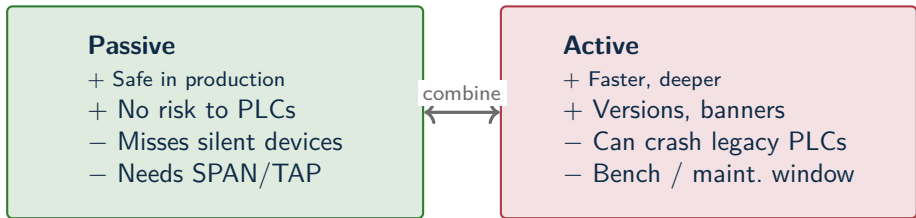
2

Asset Inventory and Scanning

Section 06 – Vulnerabilities and Assessment



“You can't protect what you don't know you have.” Firmware version is required to match CVEs.



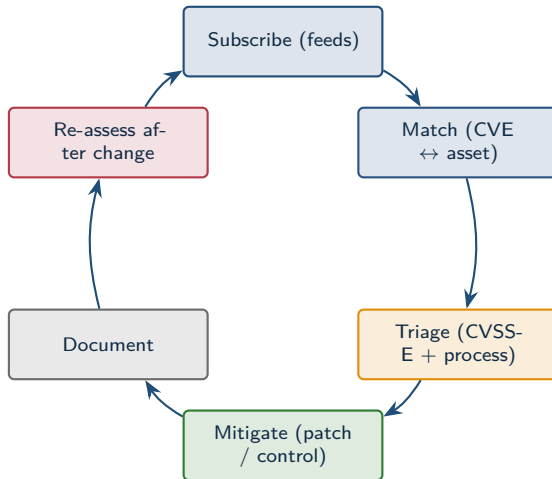


```
1 # Bench only -- never on production
2 nmap -sT -p 102,502,20000,44818,20256 \
3   --max-rate 5 --scan-delay 200ms \
4   -Pn 192.168.10.10
5
6 nmap -p 102 --script s7-info 192.168.10.10
7 nmap -p 502 --script modbus-discover 192.168.10.10
```

3

Vulnerability Management Workflow

Section 06 – Vulnerabilities and Assessment



Coordinated disclosure

Bug bounty

Silent fix

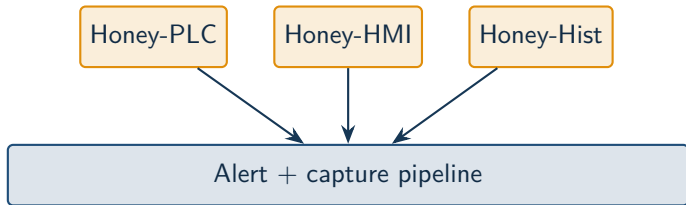
Why ICS lags

Vendor patch cycles average **90–180 days**; many critical CVEs are released without code. Always check the security advisory page weekly, not the homepage.

- **CWE-798** – hard-coded credentials in firmware
- **CWE-22** – path traversal in web UIs
- **CWE-787** – out-of-bounds write in protocol parsers
- **CWE-306** – missing authentication on critical functions
- **CWE-352** – CSRF in HMI web interfaces
- **CWE-918** – SSRF in cloud connectors

Pattern recognition

Once you have read 50 ICS advisories you will start to recognise the same weaknesses across vendors.



Examples

conpot (open-source), GasPot, Cymmetria; sector-tailored ICS honeypots from MITRE Caldera and Dragos.



Drives priority

The classification determines patch SLA, monitoring depth, and acceptable downtime.

	IT	OT
Critical CVE	48–72 hours	30–90 days, with vendor approval
Normal patch	Monthly Patch Tuesday	Annual maintenance window
Reboot tolerance	Routine	Co-ordinated, with operators
Rollback plan	Standard	Mandatory + tested

Compensating controls

When you cannot patch quickly, deploy a virtual patch (IPS rule) or tighten the firewall around the affected service.

★ Key Takeaway: What to remember from this section

- Track CVEs from CISA, vendor PSIRTs, and threat intel feeds.
- Asset inventory with firmware versions is the foundation.
- CVSS base alone misleads – always add environmental and process impact.
- Active scans only on test benches; passive sniffing is the production-safe default.

End of Section 06



Vulnerabilities and Assessment

Questions and discussion